DATHEON / APPLICATION SECURITY

Task 4 — Public API Shielding, PII Masking & DAST Report

Datheon Application Security & API Pentesting Internship · 30 October–27 November 2026

Adil Firoz · Batch 01 · The Neotia University · B.Tech Computer Science and Engineering (Cybersecurity)

LOCAL SYNTHETIC-DATA TRAINING PORTFOLIO

Task 4 — Public API Shielding, PII Masking & DAST Report

Adil Firoz · Datheon Application Security & API Pentesting Internship · Batch 01

The Neotia University · B.Tech Computer Science and Engineering (Cybersecurity)

Assessment type: Local synthetic-data API checks

Executive summary

The public profile endpoint uses an explicit response allowlist and masks email and phone values. Helmet adds a restrictive Content Security Policy, X-Content-Type-Options, and clickjacking protection. HSTS is limited to production/HTTPS use. Spectral, Gitleaks, and an OWASP ZAP baseline are wired into CI.

Scope and architecture

The API is a local Node.js/Express service with synthetic profiles only. The OpenAPI specification is openapi.yaml; automated integration tests verify masking and headers.

Implementation and technical analysis

The public endpoint returns only ID, display name, masked email, masked phone, and role. The masker handles recursively nested object/array values and common PII field names or recognizable values. Helmet's CSP restricts scripts, styles, connections, and framing to self; X-Frame-Options: SAMEORIGIN provides an additional legacy control. HSTS is not emitted over local HTTP.

Test procedure and results

Automated tests assert that the raw synthetic email and phone do not appear in the response and verify the configured CSP, frame, and MIME-sniffing headers. The local test/build/API-lint outcomes in the PDF are measured from actual command results. The GitHub Actions ZAP result is pending until the workflow runs on an authenticated public repository.

Security scanning

CI is configured for Spectral OpenAPI linting, Gitleaks tracked-file secret scanning, and OWASP ZAP baseline scanning against the workflow's local app. A baseline scan is limited coverage and requires manual triage; it does not certify the application or confirm no vulnerabilities.

Evidence, conclusion, and limitations

No screenshot or remote Actions result is claimed here. Capture actual local headers and workflow artifacts when available. Masking is a defense-in-depth privacy control and must be paired with data minimization, access control, and output-schema validation.

References

- OWASP Secure Headers Project.
- OWASP API Security Top 10.

- OWASP ZAP Baseline Scan documentation.
- Spectral OpenAPI linter documentation.

Automated test execution

Vitest run: PASSED · 8/8 passed · 0 failed

Test case	RESULT	Duration
Task 4: public data and response hardening masks dynamic PII and does not return the source values	PASSED	6 ms
Task 4: public data and response hardening sets baseline security headers and a restrictive CSP	PASSED	6 ms